VULNERABILITY MANAGEMENT POLICY

POL-017 | Policy | Part of the Information Management Framework

Document ID: POL-017
Version: 1.0 — DRAFT
Classification: Internal Use
Owner: CISO
Co-Owner: CIO
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Vulnerability Management Policy
Document ID	POL-017
Version	1.0 — DRAFT
Parent Framework	IMF-001 — Information Management Framework
Related Documents	POL-005 (System Classification), POL-006 (CSV), POL-007 (Change Management), POL-009 (PAM), POL-010 (IS Risk), POL-012 (Incident Response), POL-013 (Third Party), POL-014 (Audit Trail), POL-015 (ITSM), SOP-007 (Change Management), SOP-010 (IS Risk Assessment), SOP-012 (Incident Response), SOP-013 (Vendor Risk), SOP-017 (Vulnerability Management Process), EXC-001 (Exception Management), RACI-001
Owner	CISO
Co-Owner	CIO
Approved By	[Approver Name and Title]
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose and Scope

This policy establishes the mandatory requirements for identifying, assessing, prioritising, and remediating vulnerabilities in [Company Name] systems and infrastructure. It governs vulnerability scanning, CVSS-based severity classification and remediation SLAs, patch management, penetration testing, and the handling of vulnerabilities that cannot be immediately remediated — including the GxP-validated system patching tension that requires explicit resolution.

This policy applies to all [Company Name] systems with a tier assignment, all GxP systems, all SOX ITGC systems, all network infrastructure, and all end-user devices. It applies to software vulnerabilities, configuration weaknesses, missing patches, and design-level security deficiencies identified through any means — automated scanning, penetration testing, threat intelligence, vendor advisories, or security researcher disclosure.

IMPORTANT: A vulnerability that is known but unpatched is a risk that has been chosen, not avoided. This policy requires that every known vulnerability has an explicit disposition — remediated, mitigated with compensating controls, or formally accepted with documented rationale and an owner. 'We know about it but haven't got round to it' is not an acceptable state.

2. Vulnerability Severity Classification

All vulnerabilities are classified using the Common Vulnerability Scoring System (CVSS) v3.1 base score as the primary scoring input, supplemented by contextual factors specific to [Company Name]'s environment. CVSS base score alone is not sufficient — a Critical CVSS score on an internet-facing system is a different risk than the same score on an air-gapped laboratory instrument. The severity classification drives the remediation SLA in Section 3.

Severity	CVSS v3.1 Base Score	Contextual Escalation Factors	Remediation SLA
Critical	9.0 – 10.0	Any of the following escalates a High to Critical regardless of CVSS score: — Active exploitation confirmed in the wild (CISA KEV catalogue entry or credible threat intelligence) — Vulnerability affects a Tier 1, GxP, or SOX ITGC system — Vulnerability allows unauthenticated remote code execution on any in-scope system — Vulnerability affects the backup encryption key store or PAM platform	72 hours from identification to remediation or mitigating control in place. For GxP systems: see Section 5 (GxP Patching Framework) — the 72-hour SLA applies to the mitigating control; validated state restoration timeline is separate.
High	7.0 – 8.9	Escalation to Critical per above. Contextual de-escalation to Medium	14 calendar days from identification to remediation or

Severity	CVSS v3.1 Base Score	Contextual Escalation Factors	Remediation SLA
		where: system is not network-accessible, vulnerability requires physical access, or a compensating control already prevents exploitation.	approved exception with mitigating controls.
Medium	4.0 – 6.9	Contextual escalation to High where the vulnerability is on a Tier 1 or GxP system and no compensating control exists.	30 calendar days from identification to remediation or approved exception.
Low	0.1 – 3.9	Low vulnerabilities on GxP systems are tracked in the vulnerability register and assessed for cumulative risk — multiple Low vulnerabilities on the same GxP system may collectively represent a Medium risk.	90 calendar days from identification to remediation or accepted risk.
Informatio nal	0.0 / no CVSS score	Configuration findings, hardening gaps, and best-practice deviations without a direct exploitability path.	Addressed in the next planned maintenance cycle. Tracked in the vulnerability register.

NOTE: CVSS base scores are vendor-assigned and reflect the theoretical worst-case. They do not account for your environment. Information Security is responsible for applying contextual factors — a High CVSS score on a system that is isolated, has no sensitive data, and has compensating controls is a different operational priority than the same score on your ERP. Contextual scoring must be documented and defensible.

3. Remediation SLAs and Escalation

Remediation SLAs are measured from the date the vulnerability is logged in the vulnerability register — not from the date of patch availability, not from the date of the next scheduled scan. If a vulnerability is identified and a patch is not yet available, the SLA clock still runs: a mitigating control must be in place within the SLA window even if the patch itself is not yet available.

SLA Milestone	Requirement
SLA clock start	Date vulnerability is logged in the vulnerability register by Information Security. For scan-identified vulnerabilities: the date the scan completed. For manually identified or threat-intelligence-sourced vulnerabilities: the date reported to Information Security.
Acknowledgement	Information Security acknowledges all Critical and High vulnerabilities within 4 hours of logging. System Owner notified within 4 hours for Critical, 24 hours for High.
Remediation or mitigating control	Within the SLA window per Section 2. Remediation means the vulnerability is resolved — the patch is applied and verified, or the

SLA Milestone	Requirement
	misconfiguration is corrected and verified. A mitigating control (e.g., network isolation, WAF rule, access restriction) is acceptable within the SLA only where the definitive remediation requires additional time (e.g., vendor patch not yet available, GxP revalidation required).
SLA breach — escalation	Any vulnerability that breaches its SLA without an approved exception triggers automatic escalation: Critical SLA breach → CISO and CIO notified immediately; High SLA breach → CISO notified; Medium SLA breach → Information Security Manager notified. SLA breach is logged as an IS Risk Register finding (SOP-010).
Exception	Where remediation cannot be completed within the SLA for documented reasons, an EXC-001 exception is required before the SLA window closes — not after. See Section 6.

4. Scanning Requirements

Vulnerability scanning is a continuous programme, not a periodic project. The scanning cadence reflects the rate at which new vulnerabilities are disclosed and the risk profile of the systems being scanned.

Scan Type	Scope	Frequency	Owner
Authenticated network vulnerability scan	All Tier 1 and Tier 2 systems, all GxP systems, all SOX ITGC systems, all network infrastructure	Weekly minimum. After any significant change to the system or its network environment.	Information Security
Authenticated network vulnerability scan — Tier 3/4	All Tier 3 and Tier 4 systems	Monthly minimum.	Information Security
Web application scan (DAST)	All internet-facing web applications and APIs	Monthly minimum. After any significant application release.	Information Security / Application Owner
Container and image scan	All container images used in production	On every image build (CI/CD pipeline integration). Weekly scan of running container inventory.	Data Custodian (IT) / DevOps
Cloud configuration	All cloud infrastructure	Continuous	Information Security

Scan Type	Scope	Frequency	Owner
scan (CSPM)	(IaaS, PaaS) — all tiers	(automated). Weekly report to Information Security Manager.	
End-user device scan	All managed end-user devices (laptops, workstations)	Weekly via endpoint agent.	Information Security
Penetration test — internal	Tier 1 systems and GxP systems	Annual minimum.	Information Security (commissioned externally)
Penetration test — external	All internet-facing systems and applications	Annual minimum. After major architecture changes.	Information Security (commissioned externally)

Scan credentials must be stored in the PAM platform (SOP-009) and rotated per the PAM credential rotation schedule. Scanning must be performed from a network segment with visibility to the target systems — a scan that cannot reach its targets due to network segmentation is not a valid scan for compliance purposes. Information Security confirms scan reach is adequate at each annual vulnerability programme review.

> **NOTE:** GxP system scans must be scheduled in coordination with Compliance / QA. Some scanning activity (particularly authenticated scans with high request rates) can generate audit trail entries that appear anomalous on GxP systems. Pre-authorisation of scan activity in the SOP-007 change calendar prevents scan-generated audit trail entries from triggering false DIRA investigations.

5. GxP Validated System Patching Framework

This section resolves the structural tension between vulnerability remediation SLAs and GxP validation obligations. Both are non-negotiable — but they operate on different timescales and require explicit coordination. The resolution framework below is the mandatory approach for all GxP system patching decisions.

5.1 The Tension

Patching a GxP validated system is a Change under SOP-007. Depending on the nature of the patch, it may affect the validated state and require a Validation Impact Assessment (VIA) — and potentially re-execution of IQ, OQ, or PQ elements before the system can be used for GxP activities. This takes time. A Critical CVE on a GxP system has a 72-hour SLA. These two facts must be managed explicitly, not ignored.

5.2 Resolution Framework

Scenario	Required Response	GxP Validated State
Critical or High CVE — patch available — vendor confirms no impact on validated functionality	Emergency Change (SOP-007). CISO authorises. VIA conducted: if vendor confirmation and Information Security assessment agree there is no impact on validated functionality, patch applied within SLA. Compliance / QA notified, reviews VIA, confirms concurrence. Audit trail review post-patch.	Validated state maintained — patch does not affect validated functionality per VIA. VMF entry: patch applied, VIA reference, Compliance / QA concurrence.
Critical or High CVE — patch available — VIA assessment needed — patch may affect validated state	Step 1 (within 72hr for Critical, 14 days for High): Implement a mitigating control to close the exploitation path without patching — network isolation, WAF rule, access restriction, or disabling the vulnerable feature. This satisfies the SLA. Step 2 (within 30 days): Apply the patch under a Normal or Major Change with full VIA. Compliance / QA reviews. Partial or full OQ re-execution as VIA determines.	Mitigating control maintains validated state (no patch applied yet). Full patch requires validation activity before GxP system returns to validated status. Compliance / QA confirms validated state before GxP activities resume after patching.
Critical or High CVE — no patch available (zero-day or delayed vendor fix)	Mitigating control implemented within the SLA window. IS Risk Register entry (SOP-010) — open risk with mitigating controls. SLA exception approved via EXC-001 with CISO sign-off. Re-assessed at each subsequent weekly scan until patch is available.	Validated state maintained. Mitigating control documented in VMF as an interim security measure. Risk acceptance documented and owned by CISO.
Medium or Low CVE on GxP system	Normal Change scheduled within the remediation SLA. VIA conducted. GxP impact assessed. Remediation scheduled to minimise disruption to GxP operations.	Full VIA and Compliance / QA review. Validated state confirmation before and after patching.
GxP system where patching would require full revalidation and system cannot be taken offline	This is an IS risk requiring formal risk acceptance. Mitigating controls implemented. EXC-001 exception required with: CISO approval, CIO approval, Compliance / QA Director approval. Maximum exception duration: 6 months. IS Risk	Validated state unaffected (no patch applied). The open vulnerability is a documented risk with named owner and treatment plan.

Scenario	Required Response	GxP Validated State
	Register entry. Board notification for Critical vulnerabilities in this state.	

5.3 Principles

- The 72-hour Critical SLA applies to the mitigation, not necessarily the patch. But a mitigating control is not a permanent substitute for remediation — it buys time for a proper VIA and patching cycle. It does not remove the remediation obligation.
- Compliance / QA must be involved in every GxP patching decision — not notified after the fact. Information Security and Compliance / QA jointly own the GxP patching risk assessment.
- 'The system is validated and we can't touch it' is not an acceptable long-term response to a Critical or High vulnerability. That position, if sustained, represents a risk that must be formally accepted at Board level and tracked as an open IS risk with a remediation timeline.
- GxP system vendors are required under the Technical Agreement (SOP-013) to notify [Company Name] of security patches and their potential impact on validated configurations. Vendor notification lag does not extend [Company Name]'s remediation SLA — the clock runs from the public CVE publication date or CISA KEV entry, whichever is earlier.

6. Penetration Testing

Penetration testing is a mandatory element of the vulnerability management programme. It identifies vulnerabilities that automated scanning cannot find — logic flaws, authentication bypasses, chained attack paths, and misconfiguration combinations that are individually low severity but collectively exploitable.

Requirement	Standard
Scope	Annual internal penetration test covers Tier 1 systems and GxP systems. Annual external penetration test covers all internet-facing systems and APIs. Scope is agreed with the penetration testing provider before engagement and approved by CISO.
Provider qualification	Penetration testing is performed by a qualified external provider — CREST-certified organisation or equivalent national accreditation. The same provider may not conduct the external penetration test in consecutive years without CISO approval — rotation reduces the risk of familiarity bias.
Methodology	PTES (Penetration Testing Execution Standard) or equivalent. Methodology scope confirmed in the statement of work. Black-box,

Requirement	Standard
	grey-box, or white-box engagement type determined by CISO based on the test objectives for that year.
Rules of engagement	Written rules of engagement agreed before testing begins. Testing must not: disrupt production services, delete or modify production data, exploit vulnerabilities beyond proof-of-concept without CISO approval, access personal data beyond what is necessary to demonstrate the vulnerability. GxP systems: testing activity pre-authorised as an SOP-007 change to prevent audit trail anomaly investigations.
Findings and remediation	Penetration test report issued within 14 days of testing completion. All Critical and High findings from the penetration test are treated as Critical and High vulnerabilities under this policy — the Section 2 remediation SLAs apply from the date of report receipt. CISO reviews the report. Findings tracked in the vulnerability register.
Re-testing	Critical and High findings from the penetration test are re-tested by the provider after remediation to confirm the finding is resolved. Re-test results documented in the vulnerability register and in the penetration test report supplement.
GxP	Penetration test findings on GxP systems are assessed by Compliance / QA for validated state impact. A Critical or High penetration test finding on a GxP system triggers the GxP patching framework (Section 5) and a VIA even if no patch has been applied yet — the finding itself may indicate that the validated state has already been compromised.

7. Vulnerability Exceptions and Risk Acceptance

Where a vulnerability cannot be remediated within its SLA for documented and legitimate reasons, an exception is required before the SLA expires. Exceptions are governed by EXC-001. The following constraints apply specifically to vulnerability management exceptions:

Exception Type	Approval Authority	Maximum Duration	Mandatory Conditions
Critical vulnerability — mitigating control in place, patch pending VIA	CISO	30 days (renewable once with CISO re-approval)	Mitigating control confirmed effective. IS Risk Register entry. Weekly reassessment.
Critical vulnerability — no patch available (zero-day)	CISO	Until patch is available from vendor, maximum 90 days before formal risk acceptance required	Mitigating control confirmed effective. IS Risk Register entry. CISA KEV monitoring. Weekly reassessment.

Exception Type	Approval Authority	Maximum Duration	Mandatory Conditions
High vulnerability — remediation delayed	Information Security Manager	30 days	Mitigating control confirmed effective. IS Risk Register entry.
Critical or High on GxP system — patch requires revalidation	CISO + CIO + Compliance / QA Director	90 days maximum, renewable with same approvals	Mitigating control confirmed effective. IS Risk Register entry. Remediation plan with milestones agreed. Board notification.
Critical vulnerability — formal risk acceptance (no patch, no adequate mitigating control)	CISO + CIO + Board approval	Reviewed quarterly — cannot be indefinite	This is a last resort. The vulnerability is a formal open IS risk with Board visibility. External auditors notified for SOX ITGC systems. Regulatory notification assessment for GxP systems.
Permanent exception — end-of-life system, cannot be patched or replaced immediately	CISO + CIO + Board approval	Annual review — maximum 1 year per renewal	Full network isolation from other systems required. No direct internet exposure. No access to personal data or GxP data unless no alternative exists. Replacement roadmap with funded timeline presented to Board.

NOTE: An exception is not a resolution — it is an explicit, time-bounded acknowledgement that a risk exists and is being managed. Every exception has an expiry date and a named owner. An expired exception with no follow-on action is an SLA breach, not a continued exception.

8. Threat Intelligence Integration

The vulnerability management programme is not limited to scan-identified findings. Threat intelligence — vendor advisories, CISA Known Exploited Vulnerabilities (KEV) catalogue updates, Information Sharing and Analysis Centres (ISACs), and commercial threat intelligence feeds — provides advance warning of vulnerabilities being actively exploited before a scanner signature is available.

Intelligence Source	Monitoring Requirement	Response
CISA Known Exploited Vulnerabilities (KEV) catalogue	Information Security reviews CISA KEV updates at minimum weekly. Automated alerting configured where possible.	Any CVE added to the CISA KEV catalogue that affects [Company Name] systems is immediately escalated to Critical severity regardless of CVSS base score. 72-hour SLA applies from the date of CISA KEV publication.
Vendor security advisories	Information Security subscribes to vendor security advisory mailing lists for all Tier 1, GxP, and SOX system vendors. Advisory review: within 24 hours of receipt.	Vulnerability confirmed to affect [Company Name] systems: logged in vulnerability register immediately. Severity assigned per Section 2. SLA clock starts at advisory receipt date if the vulnerability is not yet in CVE/CVSS — conservative CVSS estimate used until official score published.
Pharma / life-sciences ISAC	Information Security participates in sector-specific threat intelligence sharing relevant to life-sciences and GxP environments.	Sector-specific threats assessed for applicability to GxP systems. Compliance / QA notified of any threat intelligence relevant to GxP data integrity or audit trail integrity.
Penetration test findings	Annual penetration test (Section 6).	Findings treated as vulnerabilities under this policy from date of report receipt.
Internal discovery	Security incident investigation (SOP-012), audit trail review anomaly (SOP-014), staff report.	Logged in vulnerability register immediately. SLA clock starts at date of report to Information Security.

9. Reporting and Governance

Report	Frequency	Audience	Content
Vulnerability Programme Dashboard	Weekly	CISO, Information Security Manager	Open vulnerabilities by severity and age. SLA compliance rate. New vulnerabilities identified in the period. Exceptions in place. CISA KEV items affecting [Company Name].
Tier 1 and GxP Vulnerability Report	Monthly	CISO, CIO, Compliance / QA	Detailed status of all open Critical and High vulnerabilities on Tier 1 and GxP systems. GxP patching decisions and VIA status. Exceptions by system. Age of oldest open vulnerability by severity.
ISSG Vulnerability Report	Quarterly	ISSG (Information Security Steering Group)	Programme-level assessment: SLA compliance trends, exception volume and age, penetration test

Report	Frequency	Audience	Content
			status, risk acceptance decisions requiring Board notification, IS Risk Register items sourced from vulnerability programme.
Penetration Test Report	Annual	CISO, CIO, System Owners of tested systems	Full penetration test findings, severity, remediation status. Re-test results. Year-on-year trend where available.
Board Vulnerability Risk Summary	Annual (and on-demand for Critical open risks)	Board / Audit Committee	Executive summary of material open vulnerabilities requiring Board visibility: critical risks formally accepted, GxP patching decisions, end-of-life system risks.

10. Related Documents

Document ID	Title	Relationship
SOP-017	Vulnerability Management Process	Operationalises this policy — defines step-by-step procedures for scanning, triage, remediation tracking, penetration testing, and exception management
POL-005	System Classification Policy	System tier determines scan frequency, remediation SLA priority, and penetration test scope
POL-006	Computer System Validation Policy	GxP patching framework (Section 5) resolves the tension between vulnerability SLAs and validated state obligations; patching GxP systems requires VIA per SOP-006
POL-007	Change Management Policy	All patches are Changes under SOP-007; Critical/zero-day patches use Emergency Change; GxP patches use Normal Change with VIA
POL-009	PAM Policy	Scan credentials managed in PAM platform per SOP-009; vulnerability in PAM platform is escalated to Critical regardless of CVSS
POL-010	IS Risk Policy	Open vulnerabilities beyond SLA, accepted risks, and programme gaps are IS risks entered via SOP-010
POL-012	Incident Response Policy	Active exploitation of a known vulnerability is a security incident activating SOP-012; CISA KEV status escalates to Critical and triggers parallel

Document ID	Title	Relationship
		incident assessment
POL-013	Third Party Policy	Tier A vendor penetration test evidence is a due diligence requirement; vendor CVEs affecting [Company Name] services trigger vendor notification assessment per SOP-013
POL-014	Audit Trail Policy	Scanning activity pre-authorised in change calendar to prevent false DIRA investigations; exploitation attempts detected in SIEM are Category 5 alerts per SOP-014
EXC-001	Exception Management Policy and Register	All vulnerability remediation exceptions governed by EXC-001 subject to the constraints in Section 7 of this policy
RACI-001	Roles, Responsibilities and Authorities	Accountability for vulnerability management governance

— End of Document —

POL-017 v1.0 DRAFT | [Company Name] | INTERNAL USE

[Amendment Section] Coordinated Vulnerability Disclosure (CVD)

Applicability: This section applies only if [Company Name] develops, maintains, or distributes software products or services used by third parties (including other sites, customers, or research partners). It does not apply if [Company Name] is solely a user of commercial off-the-shelf software and does not develop software for external use. Applicability is confirmed by the CISO and General Counsel at each annual policy review and documented in the policy review record. NIS2 Article 21(e) requires entities to have policies for vulnerability handling and disclosure in the context of security in network and information systems acquisition, development and maintenance. This section defines [Company Name]'s approach to disclosing vulnerabilities discovered in its own products or services to appropriate authorities and affected parties.

9.1 Inbound Vulnerability Disclosure (Receiving Reports)

[Company Name] maintains a public vulnerability disclosure contact for security researchers and third parties to report discovered vulnerabilities in [Company Name] products or services. This is the inbound channel:
Disclosure contact: security@[companyname].com (or equivalent published contact). This address is monitored by Information Security. Acknowledgement must be sent within 5 business days of receipt.
Scope: [Company Name] products and services. Third parties reporting vulnerabilities in [Company Name]'s infrastructure (perimeter, cloud environment) are also welcomed and treated under this process.

Safe harbour: [Company Name] will not initiate legal action against researchers who report vulnerabilities in good faith, provide sufficient detail to reproduce the issue, do not exploit the vulnerability beyond what is necessary to confirm its existence, and do not access or exfiltrate data beyond the minimum necessary to demonstrate the vulnerability.
Response SLA: Acknowledgement within 5 business days. Initial triage and severity classification within 10 business days. Remediation timeline communicated to reporter within 20 business days. Coordination on public disclosure timeline once fix is available.

9.2 Outbound Vulnerability Disclosure (Notifying Authorities and Users)

When [Company Name] discovers a vulnerability in its own products or services that affects third parties, the following outbound disclosure process applies:
Step 1 — CSIRT notification (NIS2 obligation): Significant vulnerabilities discovered in [Company Name] products that are actively exploited or could be exploited to harm third parties are notified to the national CSIRT (see GOV-001/REF-001 for contacts) in coordination with the national vulnerability database (ENISA maintains a European vulnerability database under NIS2 Art. 12). Notification timeline: within 3 business days of confirming exploitability.
Step 2 — CVE assignment: For significant vulnerabilities in [Company Name] products, Information Security assesses whether to request a CVE identifier via MITRE. CVE assignment enables coordinated disclosure and allows downstream users to assess their exposure. CISO decision on CVE request within 5 business days of confirmed vulnerability.
Step 3 — Customer and user notification: When a patch or mitigation is available, affected customers and users are notified. Notification includes: description of the vulnerability and affected versions; the risk to the customer if unpatched; the available patch or mitigation; the timeline for patch availability. CISO and General Counsel approve all customer vulnerability notifications before issue.
Step 4 — Coordinated disclosure timeline: [Company Name] follows a coordinated disclosure approach: vulnerabilities are not publicly disclosed until a patch is available, OR until a maximum of 90 days after initial discovery (if no patch is available, mitigations are published at 90 days). The CSIRT may request an extension of the embargo period for national security reasons; such requests are assessed by CISO and General Counsel.
GxP products: Any vulnerability in a [Company Name] product used in a GxP-regulated context by customers requires notification to the relevant regulatory authority (FDA, EMA, MHRA) in addition to CSIRT notification. Compliance/QA Director coordinates regulatory notification. Legal holds all notifications pending review.